

Two Ways to Hold a Secret

A decision framework and matched reference-pattern pair for classified workloads in sovereign air-gapped and public cloud

James Patrick CITP MBCS

Independent architecture paper

Version 1.0 · July 2026

Published under a Creative Commons Attribution 4.0 International Licence (CC BY 4.0).

Vendor-neutral. Described at capability level; no product or provider is named or implied.

Abstract

Sovereign-cloud discourse tends to treat sovereignty as a single property that a system either has or lacks. This paper argues that the property is at least two-dimensional, and that separating **operational sovereignty** - control of infrastructure, operators and mission execution - from **cryptographic sovereignty** - control of keys, trust anchors and certificate authority - resolves much of the confusion surrounding classified workloads in the cloud.

Using that decomposition as a shared frame, the paper sets out two reference patterns for running information up to and including SECRET: an **air-gapped sovereign cloud** that maximises both forms of sovereignty, and a **public-cloud pattern** that achieves full cryptographic sovereignty while accepting a deliberate, clearly-bounded ceiling on operational sovereignty. Each pattern is described independently of any product or vendor. For each, the paper states plainly what the pattern gives, what it costs, and which residual risks it retains - including, for the public-cloud pattern, the limits that no arrangement of controls can remove.

The patterns are presented as a matched pair, with an explicit decision framework and a composability model, on the argument that the two are not competitors but neighbouring answers to be selected per workload and connected through disciplined cross-domain enforcement. The contribution is the frame and the honesty as much as the mechanisms; a pattern that names its own ceiling is more useful to an accrediting authority than one that does not.

Contents

Abstract	2
Contents	3
1 The binary that isn't	4
1.1 Scope and posture	4
2 Decomposing sovereignty	4
2.1 Operational sovereignty	4
2.2 Cryptographic sovereignty	5
2.3 Why the distinction is load-bearing	5
3 The context both patterns are built for	6
4 Shared architectural grammar	7
5 Pattern A - The Air-Gapped Sovereign Cloud	9
5.1 Intent and placement	9
5.2 Architecture	9
5.3 What it gives you	10
5.4 What it costs you	10
5.5 Residual risks retained	10
6 Pattern B - SECRET-in-Public Cloud	12
6.1 Intent and placement	12
6.2 Architecture	12
6.3 What it gives you	13
6.4 The ceiling, stated plainly	13
6.5 Compensating controls, and what they do not neutralise	14
6.6 Residual risks retained	14
7 Choosing between them	15
7.1 The decision framework	15
7.2 Composability - you do not have to choose once	16
7.3 Anti-patterns	16
8 Conclusion	17
Appendix A - Control vocabulary	18
Appendix B - Standards touchpoints	18

1 The binary that isn't

“Sovereign cloud” has become one of those terms that everyone uses and few define the same way. Providers claim it, buyers demand it, and accrediting authorities - rightly - distrust it, because the word bundles together several distinct properties and then asserts them as a single guarantee. When a capability is described as sovereign, it is worth asking which of those properties is actually being promised, because they do not travel together and they do not cost the same.

The most consequential conflation is between **controlling the machinery** and **controlling the trust**. These are different questions. One asks who runs the infrastructure, who holds physical custody, whose cleared personnel touch the management plane, and whose legal jurisdiction can compel action against the system. The other asks who holds the keys, who owns the trust anchors, and who can decide - cryptographically, not merely contractually - whether a given actor may read a given secret. A system can score highly on one and poorly on the other. You can hold the keys to a machine somebody else operates. You can operate a machine whose trust you do not fully command.

This paper makes a simple claim: once those two properties are separated and treated as independent axes, two credible patterns for running SECRET workloads in the cloud fall out naturally, and the choice between them becomes a legible engineering decision rather than a marketing argument. The first pattern maximises both properties by physically isolating the system and operating it with sovereign-cleared staff. The second climbs one axis almost to its ceiling while deliberately accepting a bounded position on the other - and its credibility depends entirely on saying so out loud.

1.1 Scope and posture

The patterns describe environments handling information up to and including SECRET, in national or coalition-equivalent terms. Information above that level is out of scope. Both patterns are described vendor- and programme-neutrally, at the level of capabilities and enforcement points rather than products. They draw on established architectural grammar - Zero Trust as set out in NIST SP 800-207, data-centric security in the STANAG 4774 and 4778 lineage, confidential computing and remote attestation, and sovereign public-key infrastructure - but the contribution here is the framing and the discipline of stating limits, not the invention of any single mechanism.

A word on posture, because it governs everything that follows. This paper treats limitations as first-class content. A reference pattern that lists only its strengths is a brochure; a reference pattern that states precisely what it cannot do is an engineering artefact an accreditor can actually use. The second pattern in particular is built around an admission - that cryptographic isolation is not the same thing as a sovereign operational enclave - and the paper argues that designing openly for that ceiling is a mark of maturity, not a weakness to be concealed.

2 Decomposing sovereignty

The frame rests on two axes.

2.1 Operational sovereignty

Operational sovereignty is control of the machinery and the people who run it. It answers: whose cleared personnel operate the management plane; who holds physical custody of the

hardware; who authorises and applies changes, patches and updates; who can observe or interdict operations; and - the sharp end - whose legal jurisdiction can compel an operator to act against the interests of the mission. A system has high operational sovereignty when the answer to all of these is “the sovereign authority, and no one else.” It has low operational sovereignty when a commercial provider's staff, subject to a foreign jurisdiction, run the plane on the sovereign's behalf.

2.2 Cryptographic sovereignty

Cryptographic sovereignty is control of trust, independent of who runs the machine. It answers: who generates and holds the master key material; who owns the root and issuing certificate authorities; who can revoke; and whether the ciphertext resting on, or moving through, someone else's infrastructure is inert to that infrastructure's operator. A system has high cryptographic sovereignty when the trust anchors and the keys never leave sovereign custody, when private keys are non-exportable, and when the party operating the infrastructure cannot, by cryptographic construction, read the protected data. Crucially, this can be true even when the infrastructure itself is operated by someone else.

2.3 Why the distinction bears weight

The two axes are load-bearing precisely because public cloud lets you climb one of them almost to the top while leaving you structurally short of the top of the other. Hold-Your-Own-Key arrangements, externalised hardware security modules and non-exportable trust anchors let a sovereign authority reach the top of the cryptographic axis inside infrastructure it does not operate. No arrangement of controls, however, lets that same authority reach the top of the operational axis inside a commercial cloud, because the operators remain the provider's and the jurisdiction remains the provider's. An air gap, by contrast, climbs both axes together - at a cost the paper will be equally plain about.

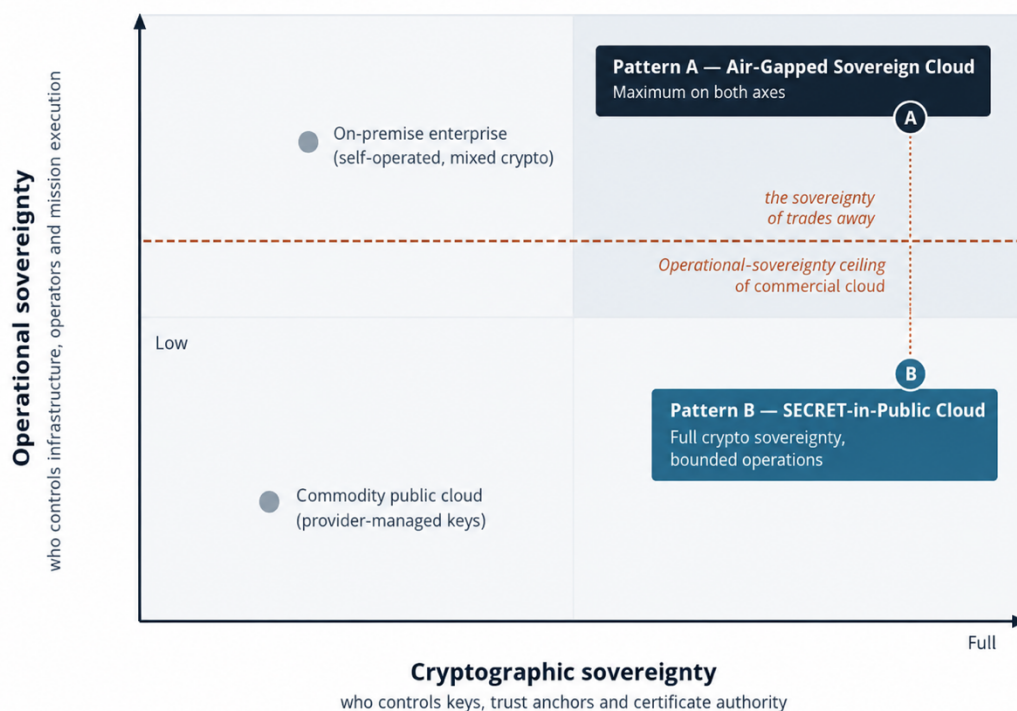


Figure 1 - The sovereignty map. Two independent axes, four reference anchors, and the two patterns. Pattern B climbs the cryptographic axis to its top but sits below the operational-sovereignty ceiling of commercial cloud; Pattern A reaches the top corner. The dashed vertical marks precisely the sovereignty B trades away for agility, scale and reach.

Two cautions about reading the map. First, position on the map is not the same as security. A workload high on both axes is not automatically more secure in every respect than one placed lower; it may in fact be less available, less current on patches, and less capable, for reasons the paper develops in Section 5. Sovereignty and security are correlated but distinct, and conflating them is one of the field's most common and most expensive errors. Second, the map is a tool for placing **workloads**, not organisations. Few real estates sit at a single point. The useful question is almost never “is my organisation sovereign?” but “where does this particular workload need to sit, and what am I willing to pay to put it there?”

3 The context both patterns are built for

Both patterns are shaped by the same operating assumptions, and it is worth stating them because they explain design decisions that would otherwise look excessive.

Presumed breach. Neither pattern assumes prevention is perfect. Both are built so that the compromise of one component does not cascade: segmentation, least privilege, containment and recoverability are treated as foundational architecture rather than as controls layered on afterwards. The design objective is not a system that cannot be breached, but a system whose breaches stay small and stay visible.

Contested and degraded conditions. Classified workloads increasingly run where connectivity is intermittent, bandwidth is constrained, and adversaries actively interfere. Both

patterns therefore favour local operational completeness over central dependency, and asynchronous, store-and-forward exchange over assumptions of continuous connectivity.

Coalition reality. In any multi-party environment there is no single trusted centre. Participants hold independent legal authorities, identity systems and assurance regimes. Both patterns therefore federate rather than centralise: trust is exchanged between sovereign domains under explicit policy, never assumed across them.

The threat environment that motivates all of this is familiar in outline - capable state actors and their intelligence services, organised crime, insider risk, supply-chain compromise, and the specific hazards introduced by AI-enabled workloads - but two categories deserve early flagging because they bear directly on pattern choice. Cross-domain movement of information is, and remains, the single highest-risk activity in any classified environment; and the eventual arrival of cryptographically-relevant quantum computing is a standing reason to demand crypto-agility of both patterns now, rather than to treat post-quantum migration as a future project.

4 Shared architectural grammar

Both patterns speak a common language. Setting it out once, here, avoids repeating it twice and sharpens the point that the patterns differ not in their vocabulary but in **where the trust boundary sits and who operates the plane**.

- **Federation, not aggregation.** Sovereign domains retain authority over their own identity, cryptography, governance and risk. Interoperability is achieved through controlled trust relationships, not by collapsing domains into a single administrative whole.
- **Trust is not inherited.** It is never conferred by infrastructure ownership, network location or administrative control. It is established - and continuously re-established - through cryptographic validation, attestation, identity federation, policy enforcement and telemetry. Connectivity is transport; it is not trust.
- **Data-centric security.** Protection and handling context travel with the payload, in the STANAG 4774 and 4778 lineage, so that information remains governed by its classification, releasability and provenance regardless of the environment currently processing it.
- **Zero Trust, default-deny, identity-aware segmentation.** No flat networks; no unrestricted lateral movement; every interaction explicitly authorised. The blast radius of any single compromise is bounded by construction.
- **A consistent regional model.** Each operational region is internally divided into a small number of segmented zones - a security and governance zone that holds the trust fabric, a workload-execution zone, a data-management zone, an operational-services zone, and a cross-domain interaction zone that is the sole authorised door in or out. A single controlled connectivity hub is the only ingress and egress point; no workload speaks directly to an external environment.
- **Sovereign public-key infrastructure.** Each domain runs an independent hierarchy with its own roots, issuing authorities and hardware security modules. Private keys are non-exportable. There are no shared roots, no shared administration, no cross-domain private-key replication.

- **Attestation.** Identity proves who an entity claims to be; attestation proves it remains in a trustworthy state. Platform integrity, runtime state and configuration are verified before an entity is trusted to participate in sensitive work - and attestation is treated as one signal among several, never as a lone anchor.
- **Continuous assurance.** Evidence is generated from infrastructure state, telemetry and policy enforcement as a matter of course, so that accreditation becomes a continuous property of the running system rather than a milestone reconstructed retrospectively. This is what makes rapid, repeatable authority-to-operate credible rather than fortunate.
- **Build once, replicate many.** Regions follow an identical, infrastructure-as-code deployable pattern, so that new regions inherit established controls and assurance artefacts rather than being redesigned - and so that both architecture and the operating organisation scale by replication.

Everything that distinguishes the two patterns is a variation on where these elements are placed and who is permitted to operate them. The grammar is shared; the sentences differ.

5 Pattern A - The Air-Gapped Sovereign Cloud

5.1 Intent and placement

Pattern A occupies the top-right corner of the map: maximum operational and maximum cryptographic sovereignty. It exists for workloads whose sensitivity, or whose threat model, or whose legal and jurisdictional constraints make **any** provider-plane exposure unacceptable - where the relevant adversary model includes the possibility of a privileged operator, or a legal compulsion on a provider, acting against the mission, and where the sovereign judges that possibility intolerable regardless of the compensating controls on offer.

5.2 Architecture

The defining move is physical isolation. There is no commercial provider control plane; the infrastructure is operated by sovereign-cleared personnel; and external connectivity is absent by default, permitted only through a diode- or cross-domain-mediated path under explicit governance. Inside the sovereign boundary, the shared regional grammar applies in full: the five zones, with the security-and-governance zone holding sovereign identity, a sovereign PKI, hardware security modules and key custody entirely in-domain, and the cross-domain interaction zone standing as the only door.

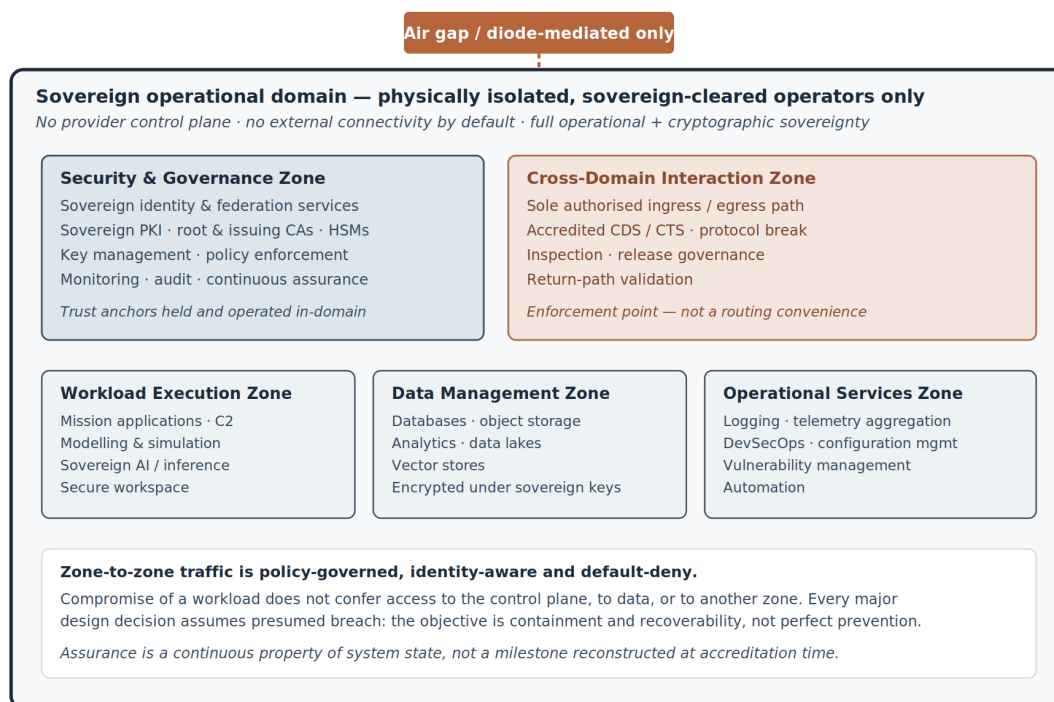


Figure 2 - Pattern A reference architecture. A physically isolated sovereign domain with in-domain trust custody and sovereign-cleared operators. External exchange is possible only through an accredited cross-domain door, at cross-domain tempo. Every zone boundary is default-deny and presumed-breach.

A point easily overlooked: in this pattern the operating **organisation** is part of the architecture, not an afterthought to it. Separation of duties across networking, platform, security operations and workloads; independent ownership of each tenancy; least-privilege administration throughout; and growth by replication rather than redesign - these are what make the pattern's

strong containment claims true in practice rather than merely on the diagram. In Pattern A, the sovereign is the cloud provider, and must be resourced and organised accordingly.

5.3 What it gives you

- **Maximum sovereignty on both axes.** The provider plane, and with it the provider's jurisdiction, is simply absent from the threat model. This is the one thing no public-cloud arrangement can offer, and for some workloads it is decisive on its own.
- **Jurisdictional exclusion.** No foreign legal instrument reaches an operator of the system, because there is no such operator.
- **A clean, defensible accreditation boundary.** Isolation makes the boundary easy to draw and easy to argue, which materially simplifies the accreditation case.
- **Strong containment and independence.** The system depends on no external connectivity and on no provider's operational decisions; its availability is a function of the sovereign's own discipline, not a third party's.

5.4 What it costs you

The costs are real and understating them is how organisations end up with expensive islands they cannot keep current. They are stated here at the same weight as the benefits.

- **Agility.** Change is slow because the sovereign owns the entire lifecycle. There is no elastic capacity to call on; capacity is bought ahead of need and stranded when demand falls.
- **AI-enablement.** Bringing frontier capability behind the gap is genuinely hard. Models age in place, and the scale of what can be run is bounded by what the sovereign can house and power. For workloads whose value depends on current, large-scale AI, the gap is a serious constraint.
- **Federation reach and coalition tempo.** Air-gapped environments are islands. Interoperability is possible only through the cross-domain door, at cross-domain tempo - which is deliberately not fast. In a coalition context this is a material limitation on how quickly the environment can participate.
- **Patch currency and supply chain.** Isolation cuts both ways. It is harder, not easier, to keep an air-gapped system current; every update is an operational event conducted across the boundary. And the gap does not remove supply-chain risk - it changes its shape, concentrating it in media, updates, hardware and firmware provenance, which are now the only ways in and therefore the paths an adversary will target.
- **Cost and sustainment burden.** High fixed cost, and a standing cleared workforce to operate the plane. This is frequently the constraint that decides the matter: many organisations that want an air gap cannot sustainably staff one.
- **Availability.** Without replicating the entire environment, an air-gapped system has fewer redundancy options than a distributed public estate. Resilience must be engineered deliberately and paid for explicitly.

5.5 Residual risks retained

Even at the top-right corner, risk is not zero. Privilege is concentrated in a small cleared workforce, which raises the salience of insider risk. Supply-chain exposure persists through media, hardware and firmware. Operator error, and physical and environmental hazards, remain.

And there is an opportunity cost that rarely appears on a risk register but belongs there: the capability the sovereign cannot run in this pattern, and the missions that go unserved as a result.

6 Pattern B - SECRET-in-Public Cloud

6.1 Intent and placement

Pattern B sits at full cryptographic sovereignty and a deliberately bounded position on operational sovereignty. It exists for workloads where the agility, elasticity, AI-enablement, federation reach and distribution-based resilience of commercial cloud are mission-decisive, and where the residual operational-sovereignty exposure can be governed down to a level the authority is willing to own. It is not a compromised version of Pattern A; it is the correct pattern for a different class of workload, and it should be chosen on its merits rather than settled for.

6.2 Architecture

The workload runs inside a cryptographically isolated tenant within the commercial provider's boundary. Zero Trust and data-centric protection apply throughout; data is encrypted at rest, in transit and - where justified - in use. The move that carries the pattern up the cryptographic axis is external key custody: master key material is held in a sovereign, externalised hardware security module and **never enters the provider boundary**. The provider operates the infrastructure but cannot, by cryptographic construction, read the protected data, because the ciphertext is inert without keys it never holds.

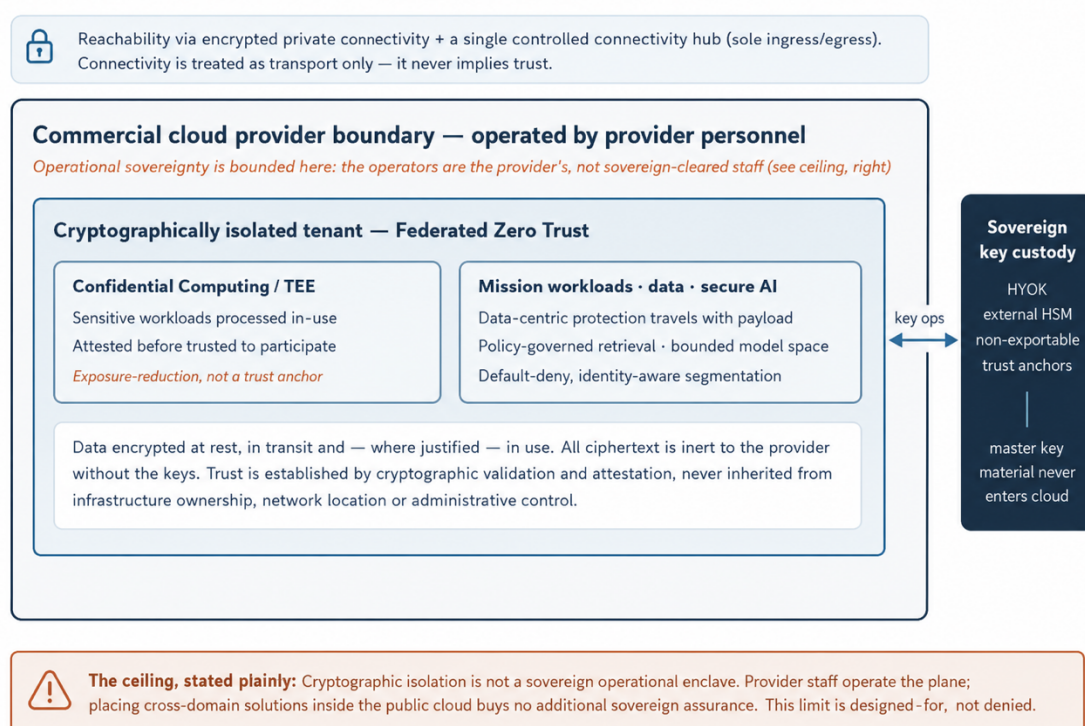


Figure 3 - Pattern B reference architecture. Cryptographic isolation inside the provider boundary, with sovereign key custody held entirely outside it. Confidential computing protects the most sensitive processing in use, but as exposure-reduction rather than a trust anchor. The operational-sovereignty ceiling is marked, not hidden.

For the most sensitive processing, confidential computing and trusted execution environments protect data in use, with attestation verifying the execution context before it is trusted. This is a genuinely valuable capability - and it is framed here, deliberately, as **exposure-reduction rather than a trust anchor**. Side-channel weakness, firmware vulnerability, enclave-

management compromise and misconfiguration remain live threats; an enclave earns trust by satisfying policy, identity, attestation and monitoring conditions, not merely by existing.

One design decision in this pattern is counter-intuitive enough to state explicitly, because getting it wrong is common. Pattern B does **not** place cross-domain solutions inside the public cloud. It would add complexity and attack surface without adding sovereign assurance, precisely because the operators inside the commercial boundary are the provider's. Cross-domain enforcement belongs at the sovereign boundary, not in the commercial tenant. Declining to deploy a control where it would be theatre is itself a mark of a serious design.

6.3 What it gives you

- **Agility and elasticity.** Capacity on demand; rapid change; no stranded fixed capital ahead of need.
- **Frontier AI-enablement.** Access to current, large-scale AI capability that is impractical to house behind an air gap - under policy-governed retrieval and a bounded model-interaction space.
- **Federation reach and coalition tempo.** Native ability to participate in distributed, multi-party operations at operational speed rather than cross-domain speed.
- **Resilience through distribution.** Availability engineered across regions and zones, drawing on the provider's distribution rather than on the sovereign replicating an entire estate.
- **Accreditation velocity.** Continuous assurance turns the evidence pipeline into a property of the running system, supporting materially faster and repeatable authority-to-operate.

6.4 The ceiling, in plain English

Cryptographic isolation is not a sovereign operational enclave.

The provider's personnel operate the plane, under the provider's jurisdiction. Placing cross-domain solutions inside the public cloud buys no additional sovereign assurance, because the operators inside that boundary are not sovereign-cleared staff. There exist adversary models - chiefly a privileged provider operator, a legal compulsion on the provider, or a sufficiently resourced attack on the operational plane - against which cryptographic sovereignty is your defence and operational sovereignty is simply not available to you.

If your threat model centres on those, Pattern B is the wrong pattern - and the honest thing is to say so, in the risk narrative, where the accrediting authority can see it. This limit is designed-for, not denied.

Everything in Pattern B's favour in Section 6.3 is true. So is the ceiling. The two statements are not in tension; holding both at once is the whole point. A pattern that names the ceiling, compensates where it can, and openly retains what it cannot compensate is more accreditable - not less - than one that asserts an unqualified sovereignty it does not possess. The credibility of the pattern is a direct function of the candour of this section.

6.5 Compensating controls, and what they do not neutralise

Controls in this pattern should be assessed not by what they are called but by which part of the exposure they actually remove. The table below is deliberately even-handed about the second column.

Control	What it buys	What it does not buy
External key custody (HYOK)	Renders data-at-rest and data-in-transit inert to the provider; a high bar against provider read-access.	Availability leverage over the tenant; full protection of operational metadata and the control plane.
Confidential computing + attestation	Reduces data-in-use exposure; verifies execution context before trust.	Elimination of side-channel, firmware and enclave-management residuals; it is exposure-reduction, not a guarantee.
Zero Trust + data-centric security	Bounds blast radius; keeps protection with the payload across environments.	Any change to who operates the plane or which jurisdiction reaches them.
Continuous monitoring & assurance	Detects anomalous behaviour; sustains audit-ready evidence.	Prevention of action by a cleared-equivalent provider operator; detection is not interdiction.
Crypto-agility / PQC readiness	Positions the estate to migrate ahead of a quantum-relevant break.	Certainty about the timing or nature of future cryptanalytic advance.

6.6 Residual risks retained

The irreducible residual is the provider-operator and jurisdiction exposure that defines the ceiling. Alongside it sit the confidential-computing residuals noted above; dependency and availability leverage held by the provider; supply-chain exposure; the AI-specific hazards of prompt injection, model poisoning and retrieval-time leakage, mitigated by constraining the model, retrieval, data-source and output spaces rather than by trusting the model to behave; and the standing future-cryptographic risk, mitigated by crypto-agility rather than removed by it. None of these is a reason not to use the pattern. Each is a reason to state the pattern's limits as clearly as its strengths.

7 Choosing between them

7.1 The decision framework

Placing a workload on the map is a matter of working through a short, ordered set of questions. The order matters: the second question can settle the decision on its own.

- **Classification and aggregation sensitivity.** How damaging is compromise, and does aggregation raise the effective sensitivity above the classification of any single item?
- **Threat model.** Does the relevant adversary model centre on the provider's operational plane or jurisdiction - a privileged operator, or legal compulsion on a provider? If yes, the analysis can stop here: this is Pattern A.
- **Operational tempo and agility.** How much does the mission depend on rapid change and elastic capacity?
- **AI-enablement.** Does the workload need current, large-scale AI that is impractical behind an air gap?
- **Federation and coalition reach.** Must the workload interoperate with distributed partners at operational speed rather than cross-domain speed?
- **Availability and resilience.** What are the continuity requirements, and can the sovereign meet them unaided?
- **Sustainment capacity.** Can the organisation actually staff and operate an air gap over the system's life? For many, honestly answered, this is the binding constraint.
- **Cost envelope and accreditation timeline.** What fixed cost is affordable, and how much schedule pressure sits on the authority-to-operate decision?

The framework does not produce a single verdict for an organisation. It produces a verdict per workload, and most real estates are mixed. The comparison below summarises how the two patterns differ across the properties that usually decide the matter.

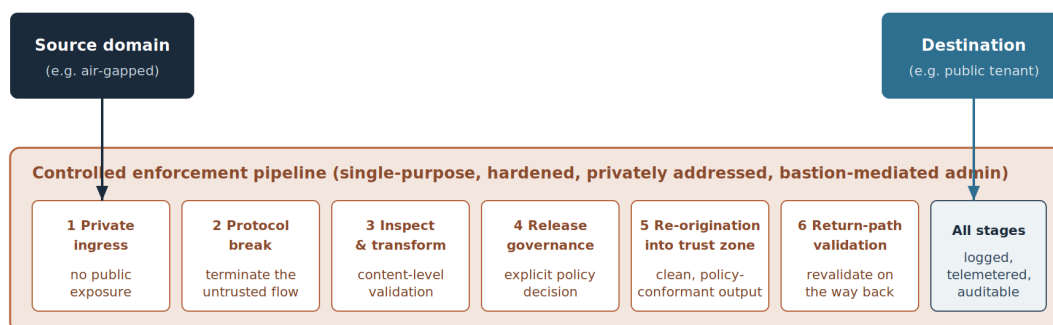
Property	Pattern A - Air-Gapped	Pattern B - SECRET-in-Public
Operational sovereignty	Full	Bounded (the ceiling)
Cryptographic sovereignty	Full	Full (external key custody)
Provider-plane exposure	None	Present, compensated, retained
Agility and elasticity	Low	High
Frontier AI-enablement	Constrained	Strong
Federation / coalition tempo	Cross-domain speed	Operational speed
Resilience model	Sovereign-replicated	Distribution-based
Patch currency	Hard; an operational event	Native and continuous
Cost and sustainment	High fixed; cleared workforce	Elastic; provider-operated
Best-fit workloads	Crown-jewel; jurisdiction-critical	Agile, AI-heavy, coalition-facing

7.2 Composability - you do not have to choose once

The most important practical point in the paper is that the two patterns are not mutually exclusive at the level of an estate. They interoperate. An organisation can run its crown-jewel, jurisdiction-critical workloads in Pattern A and its agile, AI-heavy, coalition-facing workloads in Pattern B, and connect them through disciplined cross-domain enforcement - never native trust, always explicit release.

Cross-domain transfer as an enforcement problem, not a routing problem

The mechanism by which Pattern A and Pattern B compose. Trust is never transitive across the boundary.



The destination inherits only what has been explicitly released, transformed and approved — never native trust in the source.

Encryption protects the transfer. Policy governs the release. Inspection validates the content. Transport alone never authorises the exchange.

Figure 4 - The composability mechanism. Cross-domain exchange treated as an enforcement problem, not a routing problem. The destination inherits only what has been explicitly released, transformed and approved; trust is never transitive across the boundary, and every stage is logged and auditable.

The enforcement chain is the same regardless of direction: private ingress with no public exposure; a protocol break that terminates the untrusted flow; content-level inspection and transformation; an explicit release-governance decision; re-origination of clean, policy-conformant output into the destination trust zone; and return-path validation on the way back. Encryption protects the transfer, policy governs the release, inspection validates the content - and transport alone never authorises the exchange. This is the resolution the whole paper builds towards: sovereignty chosen per workload, and the resulting environments connected with discipline rather than collapsed into a single false guarantee.

7.3 Anti-patterns

The failure modes in this space are consistent enough to name.

- **Treating connectivity as trust.** A reachable path is not an authorised one. Transitive trust across a federation is a defect, not a convenience.
- **Treating an enclave as a sovereignty substitute.** Confidential computing reduces exposure; it does not confer operational sovereignty, and presenting it as though it does is the most seductive error in the field.
- **Deploying cross-domain solutions inside public cloud “for assurance.”** Where the operators are the provider's, this is theatre: complexity and attack surface without sovereign benefit.
- **Assuming air-gapped means more secure for every property.** It does not. It can mean less available, less current and less capable. Sovereignty is not a synonym for security.

- **Monolithic trust.** A single identity authority, a single key anchor or a single management plane governing everything is a single point of catastrophic failure dressed up as simplicity.
- **One-size-fits-all sovereignty decrees.** Mandating a single pattern across an entire estate ignores that the right answer is per-workload, and usually results in either stranded capability or unacknowledged exposure.
- **Sovereign-washing.** Claiming sovereignty from a control that delivers only one axis. The two-axis frame exists precisely to make this claim falsifiable.

8 Conclusion

Sovereignty in the cloud is not one property but at least two, and most of the confusion in the field dissolves once operational and cryptographic sovereignty are separated and treated as independent axes. On that map, two credible patterns for running SECRET workloads stand out. Pattern A reaches the top corner by isolating the system and operating it with sovereign-cleared staff, and pays for that position in agility, capability, reach and cost. Pattern B climbs the cryptographic axis to its top inside infrastructure it does not operate, and buys agility, AI-enablement, reach and resilience - at the price of a bounded position on the operational axis that no control can lift, and that the pattern is stronger for naming.

The posture the paper argues for is the same in both cases: state the limits as first-class content, choose the pattern per workload rather than per organisation, and compose the resulting environments with disciplined cross-domain enforcement rather than collapsing them into a single unqualified claim. An architecture that knows exactly what it cannot do is worth more, to the people who must accredit and operate it, than one that promises everything. Holding a secret well is less about the strength of any single wall than about knowing precisely which wall you are standing behind, and being honest about the one you are not.

Appendix A - Control vocabulary

- **Operational sovereignty** - control of infrastructure, operators, the management plane and the jurisdiction reaching them; the ability to exclude a foreign operator or legal instrument from touching the system.
- **Cryptographic sovereignty** - control of keys, trust anchors and certificate authority such that protected data is inert to any party operating the underlying infrastructure.
- **Hold-Your-Own-Key (HYOK) / external key custody** - key management in which master key material is generated and held outside the infrastructure provider's boundary and never enters it.
- **Confidential computing / trusted execution environment** - hardware-isolated processing that protects data in use; treated here as exposure-reduction, verified by attestation, never as a lone trust anchor.
- **Attestation** - cryptographic evidence that a platform or workload remains in a trustworthy state; a signal to be combined with identity, policy and monitoring.
- **Data-centric security** - protection and handling context bound to the payload so that governance persists across environments (STANAG 4774 / 4778 lineage).
- **Cross-domain enforcement** - controlled ingress, protocol break, inspection, transformation, release governance, re-origination and return-path validation; the mechanism by which the two patterns compose without conferring transitive trust.
- **Continuous assurance** - generation of accreditation evidence from live system state, making accreditation a property of the running system rather than a periodic exercise.
- **Presumed breach** - the design assumption that compromise is possible, prioritising containment, visibility and recoverability over the pursuit of perfect prevention.

Appendix B - Standards touchpoints

The patterns are constructed from, and are consistent with, established public standards and guidance. This paper cites them as touchpoints for the reader, not as a compliance mapping.

- **NIST SP 800-207** - Zero Trust Architecture.
- **NIST SP 800-53** - security and privacy controls.
- **STANAG 4774 / 4778** - confidentiality metadata and data-centric labelling for the coalition context.
- **ISO/IEC 27001 family** - information-security management.
- **Confidential Computing and remote-attestation specifications** - for in-use protection and execution-context verification.
- **Post-quantum cryptography standards and crypto-agility guidance** - as the basis for the future-cryptographic-risk posture of both patterns.
- **HM Treasury Orange Book** - risk-appetite principles, applicable when calibrating tolerance differently for the two patterns.

© 2026 James Patrick. This work is published under a Creative Commons Attribution 4.0 International Licence (CC BY 4.0). You are free to share and adapt the material for any purpose, including commercially, provided appropriate credit is given. The patterns are described at capability level and are vendor- and product-neutral.